

Compiling Sufficient Governance Context from Declared Losses and Reachable States

Exact Observation-Contract Synthesis with Cardinality and Cost Objectives

Gaston Besanson*

Companion artifact: `sarc-authority-derivation`. Paper 5 of the SARC series, built on the pinned `sarc-suite-one-pass` artifact (arXiv 2608.18360, commit 782261e) as a read-only imported baseline.

Abstract

We call the object this paper derives and certifies a **minimal sufficient governance context**: given a finite reachable-state model, a deterministic declared verdict, and a set of candidate observable attributes, we compute sufficient observation sets, distinguish attributes that are individually indispensable from contracts that are jointly sufficient, and select among sufficient contracts under a cardinality or a declared observation-cost objective. An **observation contract** is a set of candidate attributes whose values determine the declared verdict on every reachable state; an **authority contract** is an observation contract selected under one of those objectives and bound to a gate schema. We do not declare an observation contract and hope it is complete: we *synthesize* every inclusion-minimal sufficient contract where exhaustive enumeration is affordable, and a minimum-cardinality or minimum-cost sufficient contract by SAT/MaxSAT encoding otherwise, checking each one’s sufficiency directly rather than assuming it from construction. On a real code/cloud authority domain (not planted for this purpose), the individually-indispensable core is **not sufficient** as an observation contract (six of ten candidates) and two distinct seven-attribute reducts exist; a preregistered declared-cost model separates them exactly (CH-B2: **supported**, the cheaper contract costs 6.124 against 7.354 for the alternative, both independently checked sufficient before cost is consulted). On a second, larger, constructed domain built independently of this question (thirty-five candidate properties), the same core-insufficiency pattern recurs (CH-C1: **supported**, a four-property core, minimum contract cardinality nine, at least five distinct minimum-cardinality contracts) – but the same domain’s own cost model does not separate them: CH-C2 is **not supported**, a fully explained cost tie across every known minimum-cardinality contract at 9.153, reported as found. We measure discernibility-family scaling on candidate-attribute universes up to one hundred properties, where exhaustive enumeration is expected and confirmed infeasible within a registered three-hundred-second timeout under this project’s own measured setup, while SAT/MaxSAT synthesis solves in well under a second on the same instances; MaxSAT showed no measured cardinality advantage over plain SAT on these specific families. AuthorityBench compares four baselines – a declared-only manual policy, ABAC-mining reimplemented from Xu and Stoller (2015), essential-variable analysis, and exhaustive reduct enumeration – across three domains; the declared-only baseline is not exactly sufficient on any of them. Every selected contract is checked for sufficiency, with a concrete counterexample returned on failure and a check summary (a partition-cell count and a uniformity flag, not a portable certificate) on success; this is the compiler-focused scope of the two-scope table in Section 12 – a separately coded, independently specified end-to-end case study is registered follow-up work, not claimed here.

*Universidad Torcuato Di Tella

1 Introduction

The decision problem. A pre-action authority gate is exactly as complete as whoever declared its observation set thought to be. This artifact’s own imported baseline (`specs/authority.yaml`) observes two things: whether the acting role is on an allow-list, and whether a declared order value exceeds a single scenario-wide cap. Acquiring every candidate field instead of choosing is not free either: latency, privacy exposure, and availability each carry a cost a gate pays on every decision. Between “declare an observation set by hand and hope it is complete” and “observe everything,” this paper compiles the third option: derive, from a declared loss model and a declared reachable-state model, the exact observation contracts sufficient to reproduce that model’s verdict, and select among them by an explicit objective.

Running example. Section 6’s own CH-B1 result gives the concrete shape of the problem before any formalism: on a real code/cloud execution-agent domain, the core (Section 2) is **not sufficient** as an observation contract on its own, and there are exactly two operationally different ways to close the remaining gap – the core plus **branch**, or the core plus **environment**, each independently checked sufficient. Neither is more “correct” than the other on cardinality alone; Section 6 shows a declared cost model can break the tie.

Contribution statement. This paper separates three things, and claims no more for any of them than its own evidence supports: first, a formulation of governance-context compilation as sufficient-set synthesis over a declared loss model and a declared reachable-state model (Section 2); second, an implemented pipeline – discernibility construction, SAT/MaxSAT synthesis, sufficiency checking – exposed through one packaged entry point (Sections 3–4); and third, a bounded evaluation across constructed domains, measuring semantic correctness, contract multiplicity, cost separation, and solver scaling (Sections 5–7). Test counts, correction history, and engineering-gate counts are not scientific contributions and are not presented as such.

Guarantee boundary, stated once here and held to throughout. Correctness in this paper is relative to a declared loss model, a declared candidate-attribute representation, and a declared reachable-state set – never a general safety guarantee independent of those three declarations.

Scope. This is the compiler-focused paper of the two legitimate scopes Section 12 distinguishes: formulation, implementation, and a bounded evaluation against declared, constructed models, not an end-to-end operational validation. A case study with domain-owner-specified losses, an equal-information baseline comparison, and a separately coded reference executor is registered future work (Section 14), not performed and not claimed here.

2 Problem Formulation and Guarantee Boundary

Inputs. A finite reachable set R of executable-reachable state tuples over a declared set of candidate attributes A ; a deterministic declared verdict v_M , a boolean function of one reachable tuple; and, optionally, a strictly positive additive declared observation cost $c(a)$ per candidate attribute.

Representation assumption. The full candidate-attribute projection of a reachable tuple must determine v_M ’s verdict on it – a consistency requirement on the declared model, not an assertion that observing every candidate attribute suffices for an arbitrary malformed or incomplete input.

Definition 1 (Observation contract). An observation contract is a set S of candidate attributes. S is **sufficient** for v_M on R (Definition 4) iff any two reachable tuples agreeing on every attribute in S also agree on their v_M verdict. A sufficient observation contract selected under an explicit objective (minimum cardinality or minimum declared cost) and bound to a gate schema is an **authority contract**.

Definition 2 (Participation, the one-flip criterion). Attribute a is authority-bearing for v_M iff there exist reachable tuples t, t' differing only in a – a single flip, holding every other candidate attribute fixed – whose v_M verdicts differ.

Definition 3 (The core). The set of every attribute participating by Definition 2.

Definition 4 (Sufficiency, restated via discernibility). S is sufficient for v_M on R iff, for every pair of reachable tuples whose verdicts differ (a cross-verdict pair), S intersects that pair’s *difference set* (the candidate attributes on which the pair disagrees) – machine-checked equivalent to the direct partition test above (three declared models checked, all agreeing; Skowron and Rauszer’s discernibility-matrix device, 1992).

Definition 5 (A reduct). An inclusion-minimal sufficient observation contract: sufficient, and no proper subset is.

Definition 6 (The core, restated as an intersection). The intersection of every reduct – machine-checked equal to Definition 3’s own witness-search answer wherever both are computed.

Core versus reduct, stated once, without chronology. Definition 3’s core (individual indispensability) and Definition 5’s reduct (joint sufficiency, Definition 4) are different properties in general: the core is always a subset of every reduct, but need not itself be sufficient. The registered two-state counterexample makes this precisely (candidate attributes $x, y \in \{0, 1\}$, reachable set $\{(x=0, y=0), (x=1, y=1)\}$, verdict $v_M(x, y) = x$): the core is *empty* (no reachable pair differs in exactly x or exactly y alone), trivially not sufficient, while $\{x\}$ and $\{y\}$ are each an independent singleton reduct. *If* the core happens to be sufficient, *then* it is the unique reduct – an antecedent never assumed, always decided per instance by a sufficiency check or a concrete counterexample (Proposition 1’, claims one through three; Section 13 records how this was established).

Cost boundary. Where a declared observation cost is used (Section 6), it is a declared additive score with strictly positive per-attribute weights – not necessarily a monetary cost or a measured end-to-end acquisition latency. Strict positivity is what makes a minimum-cost sufficient contract a reduct, not merely sufficient.

3 Method: From Discernibility to Selected Contracts

One algorithm, three families of instantiation. Given R, A, v_M , and optionally c : (1) materialize or receive the reachable tuple set and evaluate v_M on every tuple; (2) construct the difference set for every cross-verdict pair; (3) remove any difference set that is a proper superset of another already in the family; (4) encode the pruned family as CNF, one boolean variable per candidate attribute, one hard clause per surviving difference set; (5) select a satisfying assignment – any one (plain SAT), a minimum-cardinality one (cardinality MaxSAT), or a minimum-cost one (weighted MaxSAT, each attribute’s declared cost as its own soft-clause weight); (6) check the returned observation contract’s sufficiency directly – a check summary (a partition-cell count and a uniformity flag, `reduct.sufficiency`’s own success return, not the serialized partition) on success, a concrete counterexample pair on failure; (7) where exhaustive enumeration over $2^{|A|}$ subsets is affordable, enumerate every reduct; otherwise a repeated-resolve blocking-clause method finds a capped, explicitly labeled lower bound on minimum-cardinality-contract multiplicity, never presented as an exhaustive count.

Three separate evidence objects, never substituted for one another. A sufficiency check establishes that one specific observation contract determines v_M ’s verdict. An inclusion-minimality or cardinality/cost-optimality result establishes that the same contract cannot be made smaller, or cheaper, without losing sufficiency. A provenance record establishes that a

given number in this paper traces to a specific, reproducible run. None of these three is evidence for either of the others.

Correctness of the encoding, checked, not assumed. Every backend above is held to exhaustive reduct enumeration’s own from-first-principles answer everywhere exhaustion is affordable (three declared models checked, all exact) – a real encoding regression would be caught by this comparison, not assumed away by trusting the solver.

4 Implementation and Verification Interface

Package. `src/authority_compiler` (installable: `pip install .` or a built wheel, verified in a fresh virtual environment with no repository root, `pythonpath`, `editable install`, or sibling directory present) packages this paper’s own machinery behind one call, `derive_authority_contract`, returning a compiled `AuthorityContract`.

Returned fields, and what each one currently is. The core attributes; every reduct where exhaustion is affordable (`None` with a stated reason otherwise); the minimum-cardinality and minimum-cost reducts; the non-core attributes; a `sufficiency_certificate` field that is, currently, the same check-summary shape Section 3 describes – computed for the **core attributes specifically**, not automatically for whichever contract a caller ultimately selects; `counterexamples`, populated when the core is not sufficient; a `reachability_dependencies` field naming candidate attributes whose observed value set is a strict subset of their declared domain – a genuine but narrow signal, not full cross-attribute dependency inference; and a bound `contract_change_delta` callable (Section 7).

Verification boundary, stated plainly. The current implementation is executable checking: a caller can re-run the sufficiency check on any returned contract and get the same check summary or counterexample this paper reports. It is not yet a portable, proof-carrying runtime artifact: nothing in `sufficiency_certificate`’s current shape lets a separate consumer verify a contract’s sufficiency without re-running this artifact’s own code. Describing it as a portable certificate a downstream gate consumes without recomputation would exceed what the inspected interface establishes.

5 Evaluation Design

Five questions organize the evidence: does a selected contract preserve the declared verdict (RQ1); does the core fail to suffice, and do alternatives exist (RQ2); does a declared cost objective distinguish alternatives (RQ3); where is compilation practical (RQ4); and, not attempted here, does synthesis improve on a competent manual or conservative alternative in an independently specified operational workflow (RQ5).

Domain provenance, kept separate. Every domain this paper reports on is a declared, **constructed** executable model, never a live deployment or live production system. “Non-planted,” “organisationally plausible,” and “independently specified” are three separate properties; none of this paper’s domains claims the third.

AuthorityBench. Four baselines – manual least-privilege, ABAC policy mining (reimplemented from Xu and Stoller, TDSC 2015, independently validated against the published “Health Care Sample Policy” case study), essential-variable analysis, and exhaustive reduct enumeration – across three constructed domains (procurement, code/cloud, data-and-communications), six metrics each.

What was rerun for this revision, and what was not. This revision changes no result: it reruns no benchmark, no scaling family, and no AuthorityBench domain. `make formal`’s own checkers run on every `make release-check/make quick-reproduce` invocation, including the one gating this commit; the scaling and AuthorityBench results are read from their own already-committed outputs.

6 Results: Semantic Correctness, Alternatives, and Cost

Domain/result	Candidates	Reachable	Core	Min. contract	Cost finding
Code/cloud (CH-B1/B2)	10	15,120	6; not suff.	7 attrs, 2 reducts	6.124 vs 7.354
Large constructed (CH-C1/C2)	35	27,000	4; not suff.	9 attrs, ≥ 5	tie at 9.153

RQ1/RQ2: semantic correctness and alternatives. CH-B1 (all candidate subsets of ten candidates considered, subset-pruned) and CH-C1 each instantiate a core that is **not sufficient** as an observation contract on its own, with genuinely alternative minimum-cardinality contracts: CH-B1’s own two (core plus **branch**, or core plus **environment**), each independently checked sufficient; CH-C1’s own at least five, a genuine lower bound via the blocking-clause method, never rounded up to an exact count.

RQ3: cost separation, in one domain and not in the other. CH-B2 (fifteen thousand one hundred twenty reachable tuples swept, one thousand fourteen subsets considered) is **supported**, positive strict cost separation: the minimum-cost contract (core plus **branch**, cost 6.124) is strictly cheaper than the other minimum-cardinality reduct (cost 7.354, delta 1.230), both independently checked sufficient before cost is consulted. This is narrower than “cost separates alternatives in general”: CH-B2 selects between two contracts of the *same* minimum cardinality. CH-C2 (twenty-seven thousand reachable tuples, same domain as CH-C1) is the retained negative counterpart: **not supported**, a negative tie – every one of the five known minimum-cardinality contracts costs exactly 9.153 under this domain’s own seven-tier declared cost model. The tied contracts substitute attributes from the *same* declared cost tier for one another, so a cost model built at this granularity cannot discriminate between them.

AuthorityBench: the declared-only baseline. The manual least-privilege baseline is not exactly sufficient (Definition 4) on any of AuthorityBench’s three domains – measured across every registered domain this artifact has, not asserted from one. Mining agrees with the packaged minimum-cardinality answer on the procurement and code/cloud-core instances, and lands on the *other* known minimum-cardinality contract on the code/cloud domain – both independently verified minimum-cardinality contracts of the identical model, a tie-break divergence, not a disagreement about which attributes matter. By the registered decision rule, this comparison is **inconclusive**, reported as such rather than reframed as a win.

Two further registered results. The budget-binding scenario (v5.2) constructs a procurement scenario where the budget loss predicate actually fires – in sixty of sixty cells (one hundred thirty-seven thousand seven hundred eleven firings total) – and the derived-zero-miss guarantee held on every one. The isolated-arm re-measurement (v3.1) found a real internal-validity defect by this project’s own code inspection, registered before any fix was written; the isolation hypothesis itself was **not supported** – all thirty registered seeds, re-run under an isolated design, reproduce the prior shared-state result exactly, a direct diagnostic confirming the one loss predicate the defect could have corrupted never fired under this declared parameter set.

7 Computational Behaviour and Change Analysis

What is, and is not, separately measured. None of the registered scaling results, and none of CH-B1/CH-C1/CH-B2/CH-C2’s own checkers, separately records tuple-construction time, verdict-evaluation time, and discernibility-family-construction time as distinct numbers from solving time – checked directly against their own committed JSON, not assumed present. Where a number below is a per-backend wall-clock time, it is the backend’s own total call.

The exploratory result (v5.0, kept, degeneracy disclosed). Scaling candidate-attribute count alone ($n = 10, 30, 50, 100$) while holding the reachable set fixed at six tuples produced exact answers at every size with no distinguishable growth trend – a **degenerate** result for scaling in general: the added attributes never appear in any discernibility-family clause.

Tuple scaling (v5.1, kept). A planted two-reduct family grows the reachable set itself to one hundred thousand one tuples: the discernibility family still reduces, after pruning, to exactly one set, and both planted reducts are recovered exactly.

The primary scaling table (v5.3): combinatorial hardness.

Family	n	Reduct size (k)	Discern. family (pruned)	Exhaustive enumeration
A	30	5	125 sets	timed out, 300s
B	60	10	250 sets	timed out, 300s
C	100	15	375 sets	timed out, 300s

The three-hundred-second figure is a measured timeout under this project’s own recorded hardware and setup, not a complexity lower bound. Cardinality- and cost-MaxSAT both found the hand-proved minimum-cardinality reduct at every family regardless, each backend’s own solve call completing in well under a second – a comparison of two different workloads (find every reduct versus find one reduct under an objective), not one workload measured twice. MaxSAT showed no meaningful cardinality advantage over plain SAT on any of the three families.

The large domain (CH-C1/CH-C2). Exhaustive reduct enumeration was separately attempted, registered budget three hundred seconds, and confirmed infeasible (wall time 300.08s, against six million seven hundred twenty-four thousand five hundred twenty size-seven subsets alone).

Change analysis: monotone extension only. `contract_change_delta` handles exactly one class of change: additional tuples reachable under the SAME declared candidate schema and the SAME declared loss registry – a base contract already known sufficient, checked directly against the combined set, and, if no longer sufficient, extended by the fewest additional attributes needed while every attribute the base contract already relied on stays pinned. A change to the loss registry itself, a change to the candidate schema, or a removed reachable tuple are each a different kind of change this function does not handle and this paper does not claim it handles.

8 Claim-by-Claim Evidence

Every headline claim in this paper maps to one of ten claims a commissioned revision outline registered, adjudicated against this artifact’s own current committed state rather than copied from the outline’s own point-in-time observations. **Supported** means bounded evidence exists on checked finite instances; **Partial** means an implementation and some evidence exist but a stronger wording is not yet licensed.

#	Permitted claim	Status
C1	The selected observation contract preserves v_M ’s verdict over the supplied reachable set.	Supported on checked finite instances.
C2	CH-B1 and CH-C1 instantiate core insufficiency; CH-B1 has exactly two reducts, CH-C1 exposes at least five minimum-cardinality contracts.	Supported; both checkers ran as part of this commit’s own make formal .
C3	The implementation selects minimum-cardinality or minimum-cost sufficient contracts using distinct objectives.	Supported by implementation and bounded exactness checks.

#	Permitted claim	Status
C4	CH-B2 selects the cheaper of two equal-cardinality sufficient contracts; CH-C2’s returned alternatives tie.	Supported; a same-commit float-serialization non-determinism the commissioned reproduction found is fixed as of this lineage’s own reproduction-repair commit.
C5	The implementation executes a sufficiency check and returns a check summary on success or a concrete counterexample on failure.	Partial by design: <code>sufficiency_certificate</code> is a check summary, not a portable certificate.
C6	The built wheel supports the documented black-box example from a fresh environment.	Supported; the missing <code>build</code> prerequisite is now installed directly by <code>bootstrap.sh</code> .
C7	For additional reachable tuples under the same schema and registry, the implementation checks prior sufficiency and can extend a contract.	Implemented with supporting tests; a dedicated operational change study is registered future work.
C8	Measured computational behaviour is reported for the specific families and domains tested.	Partial: retained from registered runs, not rerun for this revision.
C9	This paper’s formulation or interface differs from the closest prior work in a specific, source-supported way.	Partial: compared against already fetch-verified sources; no fresh re-verification performed.
C10	This artifact’s reproduction claims state exactly which checks were completed and their scope.	Supported with qualifications; the external-reproduction item remains PENDING.

9 Related Work and Contribution Boundary

Nine neighbouring literature clusters, each fetch-verified, compared on input, output, objective, guarantee, and verification interface.

STPA and its descendants [16, 37, 29, 18, 27] establish a structured but human-driven analyst process; none derive, in general, a machine-checked minimal property set for a runtime gate. This paper’s derivation replaces the analyst step with a deterministic, exhaustively-verified derivation.

ABAC policy mining [36, 19] reconstructs which attributes already participate in an existing policy. This paper runs in the opposite direction, from a declared loss model forward to the observation contract a new gate must observe.

Policy-language completeness [9, 10] establishes what a combination language can express once participating attributes are already fixed; this paper contributes exactly the antecedent question.

Non-interference [12] is a semantic check of dependence between two fixed parties; Definition 2 sweeps the same comparison over every candidate attribute against every loss predicate, checked exhaustively.

Counterfactual fairness [15] applies the same comparison once, to one pre-chosen attribute; this paper applies it to every candidate attribute and adds a checked minimality result (Definition 5).

Shield synthesis [5] synthesizes a runtime monitor over an already-declared interface; this paper solves the strictly prior problem of which attributes must be observed at all, with a checked minimality guarantee (Definition 5).

Runtime enforcement and edit automata [33, 17] characterize a monitor’s corrective repertoire over an already-fixed alphabet; this paper answers the antecedent question of which attributes belong in that alphabet, with a minimality guarantee (Definition 5) neither work needs.

Controller synthesis [28, 26] presupposes an already-fixed observable alphabet; this paper derives the alphabet a controller must observe.

Capability systems [11] establish how authority, once granted, is represented and delegated, not which conditions must be checked before it is minted. This artifact’s own execution-grant mechanism is engineering informed by this lineage’s modern descendants [3, 13, 4], not a novelty claim in its own right.

Contribution boundary. Inherited: the discernibility-matrix device (Skowron and Rauszer, 1992) and standard SAT/MaxSAT encoding. Contributed: the formulation of governance-context compilation as sufficient-observation-contract synthesis, distinguishing individual indispensability from joint sufficiency and from cardinality/cost optimality; an implementation with an explicit verification boundary; and a bounded evaluation across constructed domains. This is a combination and an evaluated behaviour, not a claim that no neighbouring field could in principle provide an equivalent guarantee.

10 Limitations

- **Declared loss-model completeness** is assumed, not verified.
- **Reachability-model validity:** every result is exact *given* its own declared reachable set, not measured from a live deployment.
- **Partial observability** is not modeled.
- **Temporal and probabilistic losses** are out of scope.
- **Declared-cost validity:** not necessarily monetary cost or measured latency; no sensitivity analysis performed.
- **Families hard for exhaustive enumeration are not automatically hard for the solvers** synthesizing over their own discernibility family.
- **Contract multiplicity in the large constructed domain (CH-C1) is a lower bound,** capped at five.
- **External validation:** the reproduction packet is not itself independent evidence until an independent person runs it and reports back (external-reproduction item: PENDING).

11 Reproducibility

Four distinct properties, kept separate: semantic agreement; within-environment byte identity (this project’s own formal-double-run gate); cross-environment byte identity (the property a same-commit hash mismatch exposed as failing between `python3.11` and `python3.12/python3.13`, traced to `sum()`’s own version-dependent float summation and fixed by a declared-precision `math.fsum`); and independent-person reproduction. A commissioned automated reproduction satisfies the first three at the commit it ran against and exercised the fourth’s own infrastructure without itself being one – the external-reproduction item remains PENDING, not reassessed by this revision.

12 Conclusion

Given a declared loss model, a declared reachable-state model, and a set of candidate attributes, this paper compiles sufficient observation contracts rather than asking a gate builder to declare one by hand. On two independently constructed domains (CH-B1/CH-C1), the individually-indispensable core is not itself a sufficient contract, and genuinely alternative minimum-cardinality contracts exist; a declared cost model (CH-B2/CH-C2) separates those alternatives on one domain and does not on the other, both reported as found.

This is the compiler-focused paper of two scopes: a formulation, an implementation with a stated verification boundary, and a bounded evaluation against declared, constructed models – not an end-to-end operational validation. The stronger, operationally validated scope – an independently specified case, equal-information baselines, and a separately coded reference executor – is registered as a plan in Section 14, not performed and not claimed here.

13 Corrections

Append-only: nothing below is retracted or reworded; each correction is recorded alongside its original claim.

The v1 singleton-sufficiency overclaim (corrected v0.3). The original Proposition 1 conflated individual indispensability with joint sufficiency. A commissioned external review identified the mischaracterization; the finding was adjudicated against this artifact’s own definitions, not applied directly. Proposition 1 is superseded by Proposition 1’, not deleted.

The v5.0 degenerate scaling benchmark (disclosed v5.1). The exploratory benchmark’s own flat wall-time curve cannot be read as evidence of scaling in general. Relabelled `exploratory_v5_0`, superseded as the primary scaling claim, kept and cited.

The entangled v0.3 experiment arms and their null delta (found and corrected v0.4). A budget/ledger-sharing defect, found by code inspection, registered two-sided before any fix was written – **not supported**, with the mechanism explaining why.

Cross-environment float-serialization non-determinism (found 2026-09-14, commissioned automated reproduction). A same-commit hash mismatch traced directly to `sum()`’s own version-dependent float summation, fixed by a declared-precision `math.fsum`; no registered result changed.

This revision (v0.6.1). A commissioned revision outline identified terminology conflated across minimal/minimum, certificate/summary, constructed/live, and core/non-core, and an append-only structure that had grown chronological rather than claim-led. Every finding was adjudicated against this artifact’s own current committed state, not applied as a direct patch.

The two commissioned external review rounds preceding this one. Round one produced the core-versus-reduct correction above. Round two produced the broadened contribution v0.6’s own front matter named. Neither round’s finding was ever applied as a direct patch.

14 Supplementary Material

Historical manuscripts (v0.1 through v0.6, each frozen at its own commit), extended procurement evidence (the v2 worked instance where core and reduct coincide), proofs and checker detail, and mutation/reproduction records are preserved in the companion repository and its own `README.md` History section, not repeated here.

Registered follow-up work: the operationally validated scope. One bounded operational workflow, with domain owners independently specifying or reviewing losses, constraints, and costs before seeing a synthesized answer; equal-information baselines (an expert-authored contract, the loss-predicate syntactic read set, every candidate attribute, and the synthesized

contract); a separately coded reference decision procedure; and predeclared decision rules requiring zero verdict disagreement and every baseline reported, including one that ties or beats the synthesized contract. This protocol is registered as a plan, not preregistered as an experiment; no comparative outcome under it currently exists, and none is claimed.

Acknowledgements. Drafting, engineering, formal derivation, and citation verification were AI-assisted (Claude); the author is solely responsible for all claims.

References

- [1] Cloud Security Alliance. Cloud Controls Matrix (CCM) v4.1 – Infrastructure & Virtualization Security (IVS) domain, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming the Infrastructure & Virtualization Security (IVS) domain’s existence and its tenant-isolation/multi-tenancy-segmentation controls (one earlier aggregated result paraphrased the domain name with swapped word order; the canonical name confirmed directly against the official CSA site is ‘Infrastructure & Virtualization Security (IVS)’); direct WebFetch of the official CSA research page confirmed the current version (4.1, released January 2026, no newer major version found) and its full 17-domain list including IVS. Cited (prereg/v4-realistic-domain.md, losses_v4.cross_tenant_action) as the multi-tenant isolation source an action outside the acting role’s declared tenant scope crosses.
- [2] Gaston Besanson. One Gate Is Not Enough: Composing Stateful Pre-Action Controls for Agentic AI, 2026. WebFetch of <https://arxiv.org/abs/2608.18360>, 2026-08-31 (title/author/date confirmed); independently cross-confirmed by direct reading of the pinned sarc-suite-one-pass sibling at commit 782261e – its own README.md, RESEARCH-GUIDE.md, and paper-tex/parity-report.json all carry the identical title – this is paper 4 of the SARC series, the imported baseline this paper builds on and cites throughout.
- [3] Arnar Birgisson, Joe Gibbs Politz, Úlfar Erlingsson, Ankur Taly, Michael Vrabie, and Mark Lentczner. Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud. In *NDSS Symposium 2014*, 2014. WebSearch AND a direct WebFetch of the NDSS Symposium’s own official programme page (ndss-symposium.org), 2026-09-06: both independently confirm the exact title, the full six-author order, and the NDSS 2014 venue. Cited (paper5 draft v0.3, Section 6) as capability-system prior art for the execution grant, repositioning grant binding as engineering informed by established patterns rather than a novelty claim, per the external research review’s own comparison (review-secondary/external-research-review-2026-09-06.pdf, question 26).
- [4] Eclipse Biscuit. Biscuit, a bearer token with offline attenuation and decentralized verification, 2026. WebSearch AND direct WebFetch of both the raw SPECIFICATIONS.md document (raw.githubusercontent.com/eclipse-biscuit/biscuit/main/SPECIFICATIONS.md) and the project’s GitHub repository, 2026-09-06: both confirm the exact document title and that the project originated at Clever Cloud and is now maintained under the Eclipse Foundation (eclipse-biscuit) – a living specification with no single fixed publication year; the year field records this citation’s verification/access date. Cited (paper5 draft v0.3, Section 6) as capability-system prior art for the execution grant, per the external research review’s own comparison (review-secondary/external-research-review-2026-09-06.pdf, question 26).
- [5] Roderick Bloem, Bettina Konighofer, Robert Konighofer, and Chao Wang. Shield Synthesis: Runtime Enforcement for Reactive Systems. In *TACAS 2015 (21st International Conference on Tools and Algorithms for the Construction and Analysis of Systems)*, 2015. Direct WebFetch of <https://tugraz.elsevierpure.com/en/publications/>

- [shield-synthesis-runtime-enforcement-for-reactive-systems](#), 2026-09-08 (after the original [graz.elsevierpure.com](#) URL 301-redirected there): confirmed exact title, full four-author order, TACAS 2015, LNCS volume 9035, page range 533-548, and DOI directly from the TU Graz research portal record. Cited in NOVELTY.md’s Eighth amendment (prereg/v6.1-authoritybench-amendment.md, Step 5) as the shield-synthesis literature cluster: constructs a corrective law over an already-fixed signal interface, not a derivation of the interface itself.
- [6] MITRE Corporation. CWE-798: Use of Hard-coded Credentials, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming the exact title against the official [mitre.org](#) URL; direct WebFetch of [cwe.mitre.org/data/definitions/798.html](#) confirmed the exact title verbatim and current CWE list version (4.20, the verification-access year recorded here, not a claimed original-creation year, which was not independently confirmed from a primary source). Cited (prereg/v4-realistic-domain.md, losses_v4.secret_exposure) as the canonical weakness class the predicate detects an exposure path for.
 - [7] MITRE Corporation. MITRE ATT&CK Tactic TA0004: Privilege Escalation, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming tactic ID (TA0004), exact name, and Enterprise domain; direct WebFetch of the live official [attack.mitre.org](#) page confirmed the same. Cited (prereg/v4-realistic-domain.md, losses_v4.privilege_escalation) as the taxonomy source for a role without declared grant authority attempting to grant one anyway.
 - [8] MITRE Corporation. MITRE ATT&CK Technique T1485: Data Destruction, 2026. Two independently-worded WebSearch queries (2026-09-07/08) both confirming technique ID (T1485), exact name, and parent tactic (Impact, TA0040); direct WebFetch of the live official [attack.mitre.org](#) page confirmed the same plus one sub-technique (T1485.001). Cited (prereg/v4-realistic-domain.md, losses_v4.destructive_action_without_recovery_path) as the failure mode a destructive operation with no declared remediation operator exists to catch.
 - [9] Jason Crampton and Charles Morisset. PTaCL: A Language for Attribute-Based Access Control in Open Systems. In *POST 2012 (1st International Conference on Principles of Security and Trust)*, 2012. WebSearch, 2026-08-31: title/authors/venue/DOI corroborated across Royal Holloway’s PURE research portal, Semantic Scholar, and Springer’s own chapter page.
 - [10] Jason Crampton and Conrad Williams. On Completeness in Languages for Attribute-Based Access Control. In *SACMAT 2016 (21st ACM Symposium on Access Control Models and Technologies)*, 2016. WebFetch of <https://pure.royalholloway.ac.uk/en/publications/on-completeness-in-languages-for-attribute-based-access-control>, 2026-08-31: confirmed exact title, authors, venue, and year directly from Royal Holloway’s research portal record.
 - [11] Jack B. Dennis and Earl C. Van Horn. Programming semantics for multiprogrammed computations. *Communications of the ACM*, 1966. Direct WebFetch of https://www.princeton.edu/~rblee/ELE572Papers/Fall04Readings/ProgramSemantics_DennisvanHorn.pdf, 2026-09-08, read via page-image rendering (text extraction failed, image rendering succeeded): title ‘Programming Semantics for Multiprogrammed Computations’, authors ‘Jack B. Dennis and Earl C. Van Horn, Massachusetts Institute of Technology’, and the exact venue line ‘Volume 9 / Number 3 / March, 1966 – Communications of the ACM’, page 143, all visible directly on the rendered page. Cited in NOVELTY.md’s Eighth amendment as the foundational capability-systems

citation: the original C-list/capability primitive for representing and propagating authority once granted, not a derivation of which conditions must be checked before granting it – the common ancestor of this project’s own already-cited macaroons-ndss-2014/ucan-specification/biscuit-specification (cited elsewhere for the execution grant’s own representation, not for this distinction).

- [12] Joseph A. Goguen and José Meseguer. Security Policies and Security Models. In *3rd IEEE Symposium on Security and Privacy*, 1982. WebFetch of <https://dblp.org/db/conf/sp/sp1982.html>, 2026-08-31: confirmed exact title, author order, venue, year, pages, and DOI directly from the dblp proceedings listing.
- [13] UCAN Working Group. User Controlled Authorization Network (UCAN) Specification, 2026. WebSearch AND a direct WebFetch of <https://ucan.xyz/specification/>, 2026-09-06: both confirm the exact title and that this is a community-maintained living specification (source at github.com/ucan-wg/spec), not a dated academic paper – no single fixed publication year is stated in the document itself; the year field records this citation’s verification/access date, not a claimed publication date. Cited (paper5 draft v0.3, Section 6) as capability-system prior art for the execution grant, per the external research review’s own comparison (review-secondary/external-research-review-2026-09-06.pdf, question 26).
- [14] Moona Intelligence. SARC Shows Why Remediated Agent Actions Need to Be Re-Evaluated, 2026. WebFetch of <https://moona.ozlunara.com/intelligence/sarc-suite-remediate-regate-authority-coverage-boundary>, 2026-08-31, four separate targeted fetches, cross-checking specific quotes for exact wording (one earlier candidate quote about registering ‘sku, agent_id, day, or a grant identifier as predicates’ could NOT be re-found on a third targeted search and is treated as unverified/likely reconstructed by the fetch tool’s summarizer – NOT used anywhere in this paper). Two quotes used in the paper were each independently reproduced, word-for-word, across two separate fetch calls with different prompts: the ‘I want to be plain about the framing here...’ sentence, and finding A7’s ‘authorization identifier, an approval identifier, a nonce, or any consume on use mechanism’ sentence. The report’s own ‘215 passing tests’ (207 original + 8 new) is independently consistent with the already-committed REPLICATIONS.md’s ‘207 tests’ / ‘eight additional adversarial authority tests’, corroborating this is the correct, genuine report rather than a fabricated page. Publication date (28 August 2026) and the mirror URL (published under the organisation’s then-name, Belay Intelligence) per REPLICATIONS.md, already committed in the pinned sarc-suite-one-pass sibling and not independently re-verified here. UPDATE 2026-09-04 (draft v0.1.1): a third quote, from the report’s ‘My take’ closing section (‘a re-evaluation mechanism is only as complete as the policy it re-evaluates, and a policy’s completeness is a property of what it was configured to read, not of the architecture that calls it’), independently reproduced word-for-word across two separate fetch calls with different prompts, the second returning the full surrounding paragraph (which independently corroborates the same four coverage-boundary categories – resource identity, actor-specific identity, time, execution-specific grant binding – already cited in this entry from the earlier fetches), same cross-check bar as the two quotes above.
- [15] Matt J. Kusner, Joshua Loftus, Chris Russell, and Ricardo Silva. Counterfactual Fairness. In *Advances in Neural Information Processing Systems 30 (NeurIPS 2017)*, 2017. WebFetch of https://proceedings.neurips.cc/paper_files/paper/2017/hash/a486cd07e4ac3d270571622f4f316ec5-Abstract.html, 2026-08-31: confirmed exact title, full author order, and year directly from the NeurIPS proceedings page.
- [16] Nancy G. Leveson and John P. Thomas. STPA Handbook, 2018. WebSearch, 2026-08-31: two independent search snippets quote the document’s own title-page text (‘NANCY G.

LEVESON JOHN P. THOMAS MARCH 2018') from the flighttestsafety.org mirror; MIT PSAS canonical URL (psas.scripts.mit.edu) located and recorded as the citation url. Direct WebFetch of the PDF returned only undecoded binary/stream data, so verification rests on the indexed title-page text, not a rendered fetch – flagged for a human to re-confirm by opening the PDF directly.

- [17] Jay Ligatti, Lujo Bauer, and David Walker. Edit automata: enforcement mechanisms for run-time security policies. *International Journal of Information Security*, 2005. Direct WebFetch of <https://collaborate.princeton.edu/en/publications/edit-automata-enforcement-mechanisms-for-run-time-security-polici/>, 2026-09-08: confirmed exact title, full three-author order, journal name, volume/issue (4(1-2)), page range (2-16), February 2005, and DOI directly from Princeton's own research-portal record (the Springer chapter page itself 303-redirected to an access-gated IdP login and could not be fetched directly). Cited in NOVELTY.md's Eighth amendment alongside Schneider 2000 as the edit-automata half of the runtime-enforcement cluster: extends the monitor's corrective repertoire (insert/suppress, not just truncate) over the same already-fixed action alphabet Schneider fixes, without deriving that alphabet.
- [18] Simon Mylius. Systematic Hazard Analysis for Frontier AI using STPA, 2025. WebFetch of <https://arxiv.org/abs/2506.01782>, 2026-08-31: confirmed exact title, sole authorship by Simon Mylius, and June 2025 submission date.
- [19] Mohammad Nur Nobi, Maanak Gupta, Lopamudra Praharaj, Mahmoud Abdelsalam, Ram Krishnan, and Ravi Sandhu. Machine Learning in Access Control: A Taxonomy and Survey, 2022. WebFetch of <https://arxiv.org/abs/2207.01739>, 2026-08-31: confirmed exact title, full author order, 2022 submission, and that policy mining (including ABAC) is an explicit surveyed category; used as the brief's 'one recent survey' of ABAC policy mining, since it is the most recent taxonomy-level survey found covering that problem (see NOVELTY.md for why the 2017 Servos & Osborn ABAC survey was not used instead: broader scope, not recent).
- [20] National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5) – control AC-3, Access Enforcement, 2020. Two independently-worded WebSearch queries (2026-09-10) both returning the identical control ID/title/family (Access Control) and definition across independent mirrors (csf.tools, UpGuard, STIG Viewer, GRC Academy) that publish NIST's own OSCAL/JSON catalog verbatim – 'AC-3 requires organizations to enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies', explicitly distinguished from AC-2 (who gets access) and AC-6 (how much access). Same parent document as the already-verified nist-sp-800-53-cm3 entry; NIST's own interactive control browser is a JS single-page app not directly text-fetchable, so the control text itself rests on the third-party mirrors, matching that entry's own flagged caveat. Cited (prereg/v8-large-realistic-domain.md, losses_v8.unauthorized_mutation) alongside RBAC96 as the access-mediation source a mutating operation must be checked against.
- [21] National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5) – control AC-6, Least Privilege, 2020. Two independently-worded WebSearch queries (2026-09-10) both returning the identical control ID/title/family (Access Control) and definition across independent mirrors (UpGuard, CSF Tools, GRC Academy) – 'requiring organizations to grant users and processes only the minimum access necessary to perform assigned tasks... applies to all system identities, including human users, automated processes, and service accounts', both searches explicitly confirming the automated-process

scope. Same parent document as the already-verified `nist-sp-800-53-cm3/nist-sp-800-53-ac3` entries, same third-party-mirror caveat. Cited (`prereg/v8-large-realistic-domain.md`, `losses_v8.automated_actor_manual_only_operation`) as the least-privilege source for why a fully-automated principal performing a role grant is flagged regardless of its own declared operation ceiling.

- [22] National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5) – control CM-3, Configuration Change Control, 2020. Two independently-worded WebSearch queries (2026-09-07/08) both returning the identical control ID/title/family (Configuration Management) across independent mirrors (`csf.tools`, UpGuard, GRC Academy, GSA) that publish NIST’s own OSCAL/JSON catalog verbatim; direct WebFetch of the official NIST publication landing page confirmed the parent document’s exact title and revision (5, original 2020, most recently updated as Release 5.2.0, 27 August 2025 per NIST’s own change-summary). NIST’s own interactive control browser is a JS single-page app not directly text-fetchable, so the control text itself rests on the third-party mirrors, not a direct NIST plain-text fetch – flagged for the author’s own spot-check. Cited (`prereg/v4-realistic-domain.md`, `losses_v4.production_deployment_without_approval`) as the change-management source a production deployment requires a recorded approval before it applies.
- [23] European Parliament and Council of the European Union. Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications), 2002. WebSearch, 2026-09-08: official EUR-Lex location and Official Journal citation (L 201, 31/07/2002, pp. 37-47) confirmed; Article 5(1)’s confidentiality-of-communications text (‘Member States shall ensure the confidentiality of communications... shall prohibit listening, tapping, storage or other kinds of interception or surveillance of communications... without the consent of the users concerned’) retrieved directly. Cited in `prereg/v6.1-authoritybench-amendment.md`’s ‘`unconfidential_channel`’ loss predicate.
- [24] European Parliament and Council of the European Union. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), 2016. WebFetch of <https://eur-lex.europa.eu/eli/reg/2016/679/oj>, 2026-09-08 (title, regulation number, adoption date, and Official Journal citation confirmed directly from the official EU legislative portal); Article 6(1) (lawful bases), Article 9(1)/9(2) (special category data, ten enumerated exceptions – legitimate interest confirmed NOT among them via a second direct fetch of `gdpr-info.eu/art-9-gdpr/`, 2026-09-08), Article 17 (erasure), Article 44 (general principle for transfers), and Article 5(1)(e) (storage limitation) are each cited by name in `prereg/v6.1-authoritybench-amendment.md`’s own loss-predicate table, not paraphrased from memory.
- [25] Zdzisław Pawlak. Rough Sets. *International Journal of Computer and Information Sciences*, 1982. Direct Read of the paper’s own PDF first page (fetched via a WebSearch-located mirror, `sci2s.ugr.es/keel/dataset/includes/catImbFiles/1982 - Pawlak.pdf`, 2026-09-06): title ‘Rough Sets’, author ‘Zdzisław Pawlak’, header line ‘International Journal of Computer and Information Sciences, Vol. 11, No. 5, 1982’, and page number 341 all visible directly on the rendered title page, not merely an indexed snippet. DOI cross-confirmed via WebSearch (`scirp.org`’s reference listing; Springer’s own article page at `link.springer.com/article/10.1007/BF01001956`). Cited (`prereg/v3-core-reduct-`

correction.md; paper5 draft v0.3) as the foundational source for the core/reduct distinction Proposition 1' corrects to.

- [26] Amir Pnueli and Roni Rosner. On the synthesis of a reactive module. In *POPL 1989 (16th ACM Symposium on Principles of Programming Languages)*, 1989. Two independently-worded WebSearch queries (2026-09-08) both returning the identical title, both authors, POPL 1989 venue, page range 179-190, and DOI 10.1145/75277.75293 (the ACM DL page itself returned 403 Forbidden to a direct WebFetch); both searches also independently distinguished this paper from the authors' related but distinct 'On the synthesis of an asynchronous reactive module' (ICALP 1989), confirming no conflation between the two. Cited in NOVELTY.md's Eighth amendment as the temporal-logic/reactive-synthesis half of the controller-synthesis cluster: constructs a winning strategy over already-declared input/output signals, not a derivation of which signals must be declared.
- [27] Yi Qi, Yi Dong, Siddhartha Khastgir, Paul Jennings, Xingyu Zhao, and Xiaowei Huang. STPA for Learning-Enabled Systems: A Survey and A New Practice, 2023. WebFetch of <https://arxiv.org/abs/2302.10588>, 2026-08-31: confirmed exact title, full author order, 2023, and that the abstract itself introduces DeepSTPA as this paper's extension of STPA's control-loop model to the ML development lifecycle.
- [28] P. J. Ramadge and W. M. Wonham. Supervisory Control of a Class of Discrete Event Processes. *SIAM Journal on Control and Optimization*, 1987. Direct WebFetch of <https://collaborate.princeton.edu/en/publications/supervisory-control-of-a-class-of-discrete-event-processes/>, 2026-09-08: confirmed exact title, both authors, journal name, volume/issue/pages (25(1), 206-230), 1987, and DOI directly from Princeton's own research-portal record (the ACM DL page itself returned 403 Forbidden). Cited in NOVELTY.md's Eighth amendment as the discrete-event/supervisory-control half of the controller-synthesis cluster: synthesizes a maximally permissive supervisor over an already-fixed plant event alphabet, not a derivation of the alphabet itself.
- [29] Shalaleh Rismeni, Roel Dobbe, and AJung Moon. From Silos to Systems: Process-Oriented Hazard Analysis for AI Systems, 2024. WebFetch of <https://arxiv.org/abs/2410.22526>, 2026-08-31: confirmed exact title, full author order, 2024 submission, and that this is the paper defining the PHASE guideline (abstract states it directly).
- [30] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. Zero Trust Architecture (NIST Special Publication 800-207), 2020. Direct WebFetch of <https://csrc.nist.gov/pubs/sp/800/207/final>, 2026-09-10: title 'Zero Trust Architecture', publication number SP 800-207, authors Scott Rose (NIST)/Oliver Borchert (NIST)/Stu Mitchell (Stu2Labs)/Sean Connelly (DHS), publication date August 2020, all confirmed directly from the official NIST publication page – which also confirms the exact claim this citation backs, quoting the document's own abstract: zero trust 'assumes there is no implicit trust granted to assets or user accounts based solely on their physical or network location (i.e., local area networks versus the internet)', and 'the network location is no longer seen as the prime component to the security posture of the resource'. Cross-checked against a separate WebSearch query returning the same title/authors/date from NIST's own news release. Cited (prereg/v8-large-realistic-domain.md, losses_v8.external_network_zone_for_sensitive_data) as the source for network location never itself being a trust signal.
- [31] Arto Salomaa. On essential variables of functions, especially in the algebra of logic, 1963. WebSearch, 2026-09-08: exact citation ('A. Salomaa, On essential variables of functions,

especially in the algebra of logic, Ann. Acad. Sci. Fenn. Ser. A I. Math. 339 (1963) 3-11') confirmed directly via WebFetch of arxiv.org/html/math/0701332 (Couceiro, M. and Lehtonen, E., 'On the effect of variable identification on the essential arity of functions'), item [11] of its own reference list – Salomaa's 1963 paper itself predates arXiv and has no freely-accessible copy located; the arXiv URL recorded here (math/0701332) is the freely-available paper that cites it and, fetch-confirmed, states the identical mathematical definition of an essential variable this project relies on: 'there are elements $a_1, \dots, a_n, b$ such that $f(a_1, \dots, a_i, \dots, a_n) \neq f(a_1, \dots, a_{i-1}, b, a_{i+1}, \dots, a_n)$ ' – term for term Definition 1 (participation.py), independently sourced from switching/Boolean-function theory rather than rough-set theory (Pawlak 1982; Skowron and Rauszer 1992, already cited). Used in prereg/v6.1-authoritybench-amendment.md's 'essential-variable analysis' baseline.

- [32] Ravi S. Sandhu, Edward J. Coyne, Hal L. Feinstein, and Charles E. Youman. Role-Based Access Control Models. *IEEE Computer*, 1996. Two independently-worded WebSearch queries (2026-09-07/08), both returning the identical venue/volume/issue/pages/authors, one also returning ADS bibcode 1996Compr..29b..38S corroborating year/vol/issue/page/author-initial; direct WebFetch of the NIST-hosted author PDF mirror (csrc.nist.gov/csrc/media/projects/role-based-access-control/documents/sandhu96.pdf) confirmed the exact title and full four-author list; the DOI resolves live to IEEE Xplore. Cited (prereg/v4-realistic-domain.md, losses_v4.unauthorised_mutation) as the RBAC source a mutating operation must be mediated against the acting role's own declared authority.
- [33] Fred B. Schneider. Enforceable Security Policies. *ACM Transactions on Information and System Security (TISSEC)*, 2000. Direct WebFetch of <https://www.cs.cornell.edu/fbs/publications/EnfSecPols.pdf>, 2026-09-08, read via page-image rendering (text extraction failed, image rendering succeeded): title 'Enforceable Security Policies', author 'FRED B. SCHNEIDER, Cornell University', and the exact venue line 'ACM Transactions on Information and System Security, Vol. 3, No. 1, February 2000, Pages 30-50' all visible directly on the rendered first page, along with the paper's own abstract stating it gives 'a precise characterization... for the class of security policies enforceable with mechanisms that work by monitoring system execution' (Execution Monitoring, EM). Cited in NOVELTY.md's Eighth amendment as the foundational runtime-enforcement/EM citation: characterizes what a monitor can enforce over an already-fixed action alphabet, not which properties belong in that alphabet.
- [34] Andrzej Skowron and Cecylia Rauszer. The Discernibility Matrices and Functions in Information Systems. In *Intelligent Decision Support: Handbook of Applications and Advances of the Rough Sets Theory*. 1992. WebSearch, 2026-09-06, two independently-worded queries both corroborating the exact title, both authors, venue (Intelligent Decision Support, ed. Słowiński, Springer/Kluwer Dordrecht), year 1992, and page range 331-362, across Springer's own chapter listing and Semantic Scholar's indexed record. Cited (prereg/v3-core-reduct-correction.md) as the discernibility-matrix source reduct.py's exact reduct enumeration is positioned against.
- [35] Zhongyuan Xu and Scott D. Stoller. ABAC-Mining: implementation and case-study data for "Mining Attribute-Based Access Control Policies" (case-studies/healthcare.abac), 2014. The paper's own page 7 text ('All of the code and data is available at <http://www.cs.sunysb.edu/~stoller/>') was followed 2026-09-08; that address now 503s (WebFetch), so the current homepage was located instead (WebSearch, then WebFetch of <https://www3.cs.stonybrook.edu/~stoller/>), whose 'Software' page (software/index.html) links ABAC-Mining.zip with the description 'an implementation of the policy mining algorithms described in our 2015 IEEE TDSC paper.' Downloaded directly via curl, 2026-09-08:

32,482,151 bytes, sha256 5da1e61877585720a3276605517117a74546577f47fb82ecd026e0f7a47fd106. Its ABACMining/case-studies/healthcare.abac (sha256 4ce5c62c122a4b0d8f30da222ac8effd9a665d6fe9ff11fe3a799b3d2f68f429) is the paper’s own hand-authored ‘Health Care Sample Policy’ (Section 5’s evaluation); GPLv3 (COPYING in the same archive) – the code is not vendored into this Apache-2.0 repository, only the attribute-value and rule facts are transcribed by hand into fresh Python (xu_stoller_validation.py), the same discipline this project already applies to cited legal text. Cross-checked directly against the paper’s own PDF (fetched from <https://www3.cs.stonybrook.edu/~stoller/papers/abac-mining-TDSC.pdf>, read via page-image rendering since text extraction failed on this file): Fig. 5’s health care row (page 8: |Rules|=9, |A_u|=6, |A_r|=7, |Op|=3, |U|=21, |R|=16, |UP|=51, average per-rule coverage 6.7) and Section 5.1’s prose (page 7: with no attribute declared unremovable, the mined policy drops the redundant ‘type=HRIitem’ RAE conjunct from exactly four rules, otherwise identical to the original – i.e. their own algorithm mines 9 rules on this input). ‘xu_stoller_validation.py’’s transcription independently reproduces |UP|=51 exactly (not assumed, computed) before any mining code runs against it – prereg/v6.1-authoritybench-amendment.md’s own ‘ABAC policy mining, reimplemented from Xu and Stoller’ baseline validation gate.

- [36] Zhongyuan Xu and Scott D. Stoller. Mining Attribute-Based Access Control Policies. *IEEE Transactions on Dependable and Secure Computing*, 2015. WebSearch, 2026-08-31: title/authors/venue/volume/issue/pages/DOI corroborated across the authors’ own Stony Brook policy-mining page (www3.cs.stonybrook.edu/stoller/policy-mining/) and independent bibliographic indexes; distinguished from the authors’ earlier 2013/2014 conference-track pieces (CEWIT 2013, DBSec 2014) on the same problem, per the task brief’s ‘2014-2015’ framing. UPDATE 2026-09-08 (prereg/v6-authority-bench.md, Milestone E2): WebFetch of <https://arxiv.org/abs/1306.2401>, the freely-available preprint of this same work (per the Stony Brook page’s own listing: ‘June 2013, updated August 2014’ – the earlier-venue draft of the eventual TDSC 2015 journal form already verified above, not a different paper), returned the full abstract, quoted directly in prereg/v6-authority-bench.md: ‘Our algorithm iterates over tuples in the given user-permission relation, uses selected tuples as seeds for constructing candidate rules, and attempts to generalize each candidate rule to cover additional tuples in the user-permission relation by replacing conjuncts in attribute expressions with constraints. Our algorithm attempts to improve the policy by merging and simplifying candidate rules, and then it selects the highest-quality candidate rules for inclusion in the generated policy.’ This is the only textual claim about the algorithm’s own mechanics this project relies on; prereg/v6-authority-bench.md’s own reimplementaion is registered as explicitly scoped to what this quoted abstract describes, not to the paper’s full method.
- [37] William Young and Nancy G. Leveson. An Integrated Approach to Safety and Security Based on Systems Theory. *Communications of the ACM*, 2014. WebSearch, 2026-08-31: title/authors/venue/year/DOI corroborated across cacm.acm.org, Semantic Scholar, and dblp-indexed snippets; this CACM piece is the canonical citation for STPA-Sec, distinct from the earlier informal 2013 workshop write-up.